Анализ ELK и Wazuh для сбора и хранения событий ИБ от ИИ-инструментов

1. Цель и исходные условия

До конца 4 квартала необходимо определить open-source платформу для централизованного сбора, долгосрочного хранения, сквозного поиска и анализа событий информационной безопасности, формируемых ИИ-инструментами ИТ-подразделений.

Исходные параметры контура:

- Развертывание осуществляется строго в закрытом локальном периметре (On-Premise) без использования внешних облачных сервисов (включая публичные S3-хранилища).
- Рассматриваются исключительно бесплатные версии систем: Wazuh 4.14.8 и ELK Stack 9.5.5 (лицензия Basic).
- К целевым событиям относятся: запросы пользователей (prompt), ответы моделей (response), вердикты систем защиты (guardrails), технические метаданные (идентификаторы сессий session_id, метки времени, ID пользователей).
- Сбор полных текстов промптов и ответов обязателен для проведения ретроспективных ИБ-расследований, что требует реализации механизмов маскирования чувствительных данных на лету.

2. Критерии оценки

Оценка систем проводится по жестким условиям допуска. Если система не проходит критическое требование, она не может быть выбрана в качестве целевого основного хранилища.

- Сбор и доставка: Поддержка больших сообщений (мегабайтные текстовые промпты), прямой прием по HTTP REST API от локальных микросервисов ИИ, устойчивость к пиковым нагрузкам.
- Локальное хранение и архив: Автоматическое управление жизненным циклом данных (ротация, очистка дисков), возможность сквозного поиска по историческим логам без ручной распаковки файлов.
- Маскирование на лету: Способность находить регулярными выражениями и заменять маской ПДн, пароли и коммерческую тайну до записи события на диск.
- Автоматизация и реагирование: Скорость поднятия инцидентов и возможность блокировки учетных записей злоумышленников в локальной инфраструктуре (например, Active Directory).
- Трудозатраты инженеров: Объем дефицитного времени специалистов, расходуемый на поддержку и адаптацию системы под изменения форматов логов ИИ.

3. Сравнительный анализ: механизмы работы и критические проблемы

3.1. Обработка больших текстовых сообщений (Промпты и Ответы моделей)

Как это работает в ELK Stack 9.5.5: По умолчанию лимит на размер одного входящего JSON-документа в Elasticsearch составляет 100 МБ (http.max_content_length). Буфер Logstash ограничивается только выделенной ему RAM. Система без задержек принимает длинные контексты ИИ, программный код и анализируемые документы.

Как это работает в Wazuh 4.14.8: На уровне исходного кода ядра Wazuh (компонент analysisd) установлен жесткий архитектурный лимит размера строки события — 64 КБ (#define OS_MAXSTR 65536).

⚠ Критическая проблема: При отправке длинного промпта или развернутого ответа модели ядро Wazuh безвозвратно обрежет лог. Это приведет к нарушению структуры JSON, невозможности парсинга декодерами и полной потере ИБ-контекста.

3.2. Сбор полного потока данных (Легитимный трафик vs Алерты)

Как это работает in ELK Stack 9.5.5: Стек изначально спроектирован как высокомасштабируемая база данных. Схема работы строится по принципу «пишем 100% входящего трафика, нормализуем и осуществляем поиск по всему массиву».

Как это работает в Wazuh 4.14.8: Архитектурно Wazuh заточен под фиксацию алертов (аномалий). Весь поток сырых легитимных логов по умолчанию сбрасывается в плоский файл archives.json.

⚠ Критическая проблема: Если принудительно включить полную индексацию всех архивов в базу данных Wazuh Indexer (logall_json), локальный сервер Wazuh Manager столкнется со сверхвысокой нагрузкой на CPU/RAM из-за постоянной сверки огромных объемов легитимного текста со всем набором правил SIEM.

3.3. Локальное архивное хранение и сквозной поиск

Как это работает в ELK Stack 9.5.5: Управление жизненным циклом логов реализуется через локальные политики ILM (Index Lifecycle Management). Данные автоматически и прозрачно перемещаются между локальными дисками разного типа по цепочке Hot -> Warm -> Cold.

Как это работает в Wazuh 4.14.8: Ротация логов выполняется утилитой wazuh-monitord, которая сжимает старые файлы в локальные архивы .json.gz.

⚠ Критическая проблема: Поиск по сжатым архивам Wazuh через дашборд невозможен. При необходимости расследовать инцидент трехмесячной давности инженеру ИБ придется вручную скачивать архивные файлы с дисков серверов, распаковывать их и искать данные утилитой grep.

3.4. Маскирование конфиденциальных данных на лету

Как это работает в ELK Stack 9.5.5: Встроенные механизмы Logstash (плагин mutate с функцией gsub) или Elasticsearch Ingest Pipelines (процессор Redact) перехватывают поле prompt и по регулярным выражениям вырезают секреты, подменяя их на *** до фиксации лога.

Как это работает в Wazuh 4.14.8: Штатные средства очистки текста в процессе приема лога практически отсутствуют. Требуется внешнее прокси-решение перед Wazuh для очистки трафика, что усложняет архитектуру.

3.5. Каналы приема данных и API

Как это работает в ELK Stack 9.5.5: Elasticsearch предоставляет стандартный HTTP REST API. Любой внутренний ИИ-сервис или локальный валидатор (например, Llama Guard) может напрямую отправлять события методом POST.

Как это работает в Wazuh 4.14.8: Чтобы доставить логи в Wazuh, локальные ИИ-сервисы необходимо принудительно обязать писать данные в локальный Syslog или текстовые файлы на диске, которые затем будут вычитываться агентом, что создает лишние дисковые операции (I/O).

3.6. Автоматизация реагирования

Как это работает в ELK Stack 9.5.5: В бесплатной версии Basic встроенные механизмы автоматического оповещения урезаны. Для отправки уведомлений требуется интеграция внешней бесплатной утилиты с открытым кодом ElastAlert2.

Как это работает в Wazuh 4.14.8: Реализован мощный встроенный механизм Active Response. При обнаружении атаки на ИИ Wazuh может мгновенно запустить локальный скрипт на сервере и временно заблокировать учетную запись нарушителя в Active Directory.

3.7. Анализ распределения трудозатрат инженеров

- В случае выбора ELK Stack: Основное время инженера уходит на проектирование и администрирование баз данных (настройка Mapping Templates, оптимизация индексов, настройка политик очистки дисков ILM). Это высокоэффективные трудозатраты.
- В случае выбора Wazuh: Основное время инженера превратится в «ад регулярных выражений» (PCRE). Специалисту придется вручную писать и постоянно переписывать сложные XML-декодеры под каждое изменение формата JSON от ИИ-разработчиков.

3.8. Влияние ограничений бесплатной версии ELK Basic и возможности коммерческого Премиума

Ограничения бесплатной версии ELK Basic в локальном периметре: Отсутствие разделения доступа внутри индекса (Field-level security) и отсутствие нативного алертинга (Watcher заблокирован). Требуются обходные пути: разделение на разные индексы и использование ElastAlert2.

Что дает коммерческая Premium-подписка ELK: Field-level security (гибкое скрытие полей), Searchable Snapshots (поиск по архивным снимкам в локальном MinIO/NFS без восстановления, экономящий до 80% мощностей) и встроенный локальный Machine Learning для выявления аномалий.

Критерий оценки	Wazuh 4.14.8 (Бесплатный)	ELK Stack 9.5.5 (Basic)	Решение для ИИ-задачи
Размер лога	Жесткий лимит 64 КБ. Длинные промпты будут обрезаны.	Лимит 100 МБ по умолчанию. Вмещает гигантские контексты.	ELK Stack
Сбор потока	Оптимизирован под алерты. Сбор 100% сырых логов перегрузит CPU.	Спроектирован под полный сбор и поиск по терабайтам сырого текста.	ELK Stack
Локальный архив	Архивы в плоских .gz файлах. Поиск только вручную через grep.	Локальные политики ILM. Автоперенос данных (Hot -> Cold).	ELK Stack
Маскирование	Сложно. Требует внешних скриптов-прослоек до попадания лога.	Из коробки (процессор Redact или Logstash mutate/gsub).	ELK Stack
Прием по API	Отсутствует открытый REST API для логов. Нужен Syslog/файлы.	Прямой HTTP REST API для JSON логов локальных ИИ.	ELK Stack
Автоматизация	Отличная. Механизм Active Response для блокировок в AD.	Слабая в Basic. Нужны сторонние скрипты / утилиты.	Wazuh
Трудозатраты	Написание XML-декодеров и регулярных выражений под изменения JSON.	Проектирование БД, настройка маппингов, пайплайнов и очистки дисков.	ELK Stack

4. Предлагаемый план PoC (Программы испытаний)

1. Согласование параметров: Зафиксировать перечень тестовых ИИ-источников, форматы передачи JSON, средний/пиковый EPS, а также определить размеры «длинных» промптов (от 100 КБ до 5 МБ).

2. Проверка каналов приема: Подключить локальные ИИ-источники к обеим системам. Проверить доступность прямой отправки по API в ELK и стабильность фиксации событий через локальные файлы/Syslog в Wazuh.
3. Стресс-тест на лимиты сообщений: Направить в обе системы промпты размером 128 КБ, 1 МБ и 5 МБ. Зафиксировать факт обрезания данных в Wazuh (OS_MAXSTR) и корректность индексации в ELK.
4. Тестирование аналитики и ИБ-функционала: Проверить удобство группировки событий по session_id в Kibana Lens. Оценить работу процессора Redact по маскированию тестовых ПДн.
5. Тест локальной автоматизации: Проверить скорость генерации алертов через ElastAlert2 и протестировать механизм Active Response в Wazuh на запуск локального скрипта блокировки нарушителя.
6. Нагрузочные замеры: Измерить задержку индексации при пиковом EPS, процент потери событий при сбое сети, скорость заполнения дисков и время поиска данных в локальном архиве.

5. Предварительный вывод и рекомендация

Для централизованного сбора, маскирования и долгосрочного хранения полного потока разнородных ИИ-событий бесплатная платформа Wazuh 4.14.8 аппаратно неприменима в качестве основного и единственного хранилища.

Рекомендуется утвердить гибридный On-Premise сценарий:

1. Ядро системы и единое хранилище: Развернуть бесплатный локальный кластер ELK Stack 9.5.5 (или открытый аналог OpenSearch). Весь тяжелый поток текстовых промптов, ответов и метаданных направлять напрямую в него. В Logstash реализовать маскирование ПДн и ротацию индексов по локальным дискам.
2. Движок реагирования: Если локальный ИИ-валидатор или пайплайн Logstash фиксируют критический инцидент ИБ, короткое сервисное оповещение (до 64 КБ) дублируется в локальный Wazuh для мгновенной блокировки учетной записи нарушителя в домене Active Directory через Active Response.

6. Вопросы, требующие подтверждения

1. Возможность использования бесплатного форка OpenSearch вместо оригинального Elastic Stack Basic для получения бесплатного функционала разграничения прав доступа на уровне полей лога (Field-level security).
2. Окончательный перечень локально развернутых ИИ-продуктов и готовность их команд разработки передавать логи в формате JSON по HTTP REST API.
3. Точные объемы выделяемых локальных дисковых массивов (HDD/SSD) в периметре под хранение тяжелых текстовых данных ИИ-сессий на период опытной эксплуатации.